

MULTIMEDIA UNIVERSITY, MALAYSIA

Port Scanning

ETHICAL HACKING AND PENETRATION TESTING
CCS6324 - 2530

Dr. Hafiz Adnan Hussain



DISCLAIMER



- This course is designed to educate students on ethical hacking principles. The knowledge and techniques acquired must be used responsibly and not for any illegal or unauthorized activities.
- Each student is solely responsible for their actions.
- Do not investigate individuals, websites, servers or conduct any illegal activities on any system you do not have permission to analyze.
- The course content has been developed in good faith, drawing from the author's experience and reputable sources. While every effort has been made to ensure accuracy, the author does not guarantee absolute correctness. Students are encouraged to exercise discretion and actively engage in discussions by raising any questions or concerns during the course.

Learning Objectives



What You Will Learn?

- Introduction to Port Scanning
- TCP/IP Fundamentals Review
- Understanding Ports and Services
- Types of Port Scanning
- Port Scanning Tools
- Ping Sweep Techniques
- Evasion Techniques
- Legal and Ethical Considerations

INTRODUCTION TO PORT SCANNING



What is Port Scanning?

Port scanning is the process of checking which "doors" (ports) are open on a computer or server.

Real-Life Analogy:

Imagine a huge apartment building with 65,535 doors (apartments):

- Some doors are **OPEN** (services running)
- Some doors are **CLOSED** (nothing there)
- Some doors are **LOCKED** (firewall blocking)

Port scanning is like walking around and checking which doors you can knock on!

The Reconnaissance Process

Port scanning is **Step 3** in the hacking process:

Step 1: Footprinting → "Who is the target?"

Step 2: Reconnaissance → "What domains do they own?"

Step 3: Port Scanning → "What services are running?" ← WE ARE HERE

Step 4: Enumeration → "What versions? What users?"

Step 5: Exploitation → "Attack the vulnerable service"

Why Do We Port Scan?

For Security Professionals (Good Guys):

- Find vulnerable services before hackers do
- Check if unnecessary ports are exposed
- Audit network security
- Verify firewall configurations

For Hackers (Bad Guys):

- Find entry points to attack
- Identify vulnerable services
- Map out network infrastructure
- Plan targeted attacks

TCP/IP FUNDAMENTALS REVIEW

What is TCP/IP?

TCP/IP = Transmission Control Protocol / Internet Protocol. Think of it as the "language" computers use to talk to each other on the internet.

TCP vs UDP

TCP Characteristics:

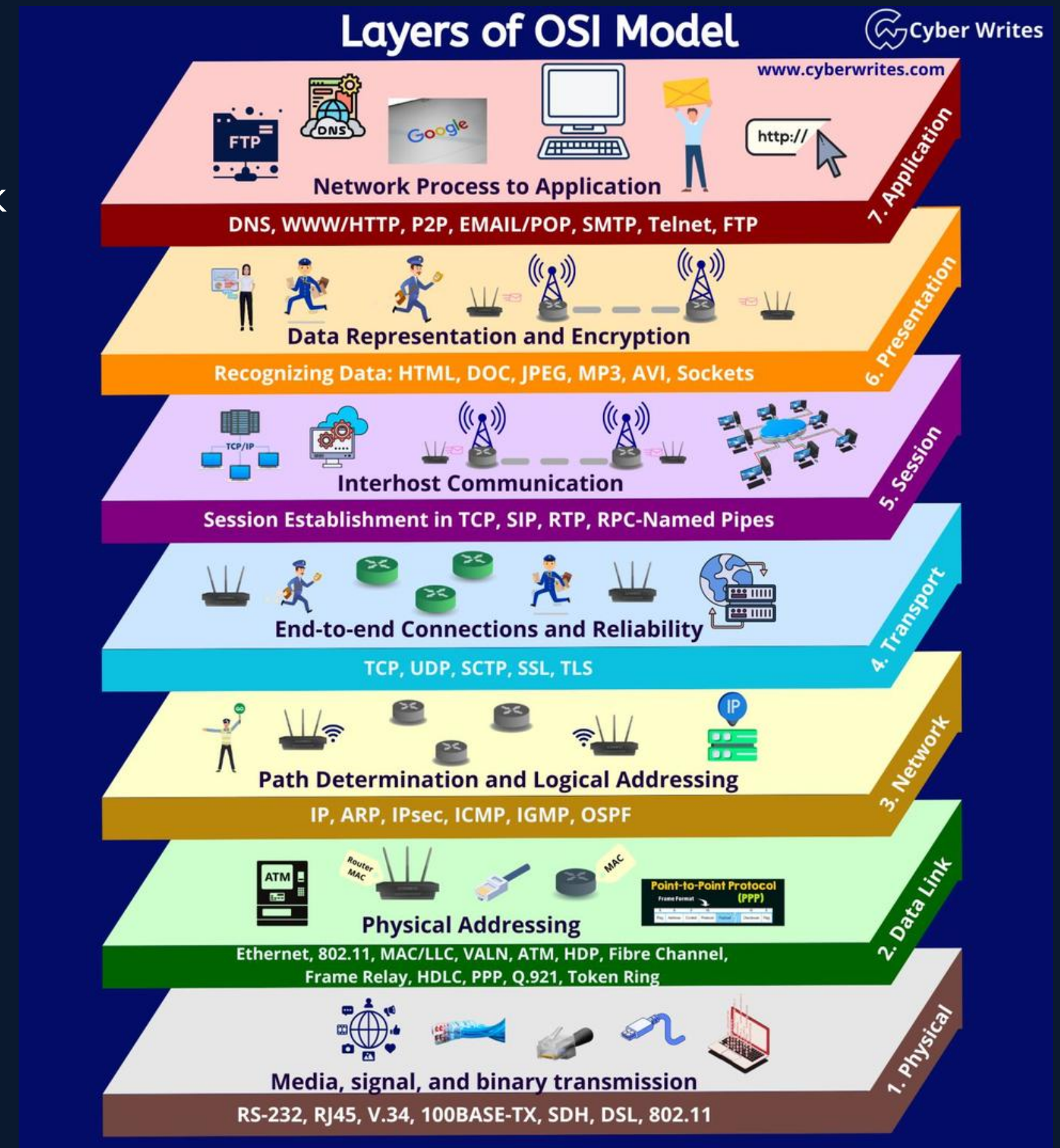
- Connection-oriented (like a phone call)
- Reliable (guarantees delivery)
- Ordered (packets arrive in sequence)
- Slower (overhead from reliability)

Uses: Web browsing (HTTP/HTTPS), Email (SMTP), File transfer (FTP)

UDP (User Datagram Protocol) Characteristics:

- Connectionless (like sending a postcard)
- Unreliable (may not arrive)
- No order (packets can arrive out of sequence)
- Faster (no reliability overhead)

Uses: Video streaming, Gaming, DNS queries



For port scanning, we care about Layer 4 (Transport)!

The TCP Three-Way Handshake

It is **CRITICAL** for understanding port scanning!



Source	Destination	Protocol	Length	Info
192.168.122.10	192.168.122.145	TCP	74	52082 → 8000 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TS
192.168.122.145	192.168.122.10	TCP	74	8000 → 52082 [SYN, ACK] Seq=0 Ack=1 Win=65160 Len=0 MSS=1460 SA
192.168.122.10	192.168.122.145	TCP	66	52082 → 8000 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=3309510324

Normal TCP Handshake/Connection:

Step-by-Step:

1. **SYN (Synchronize):** Client says, "Can we talk?"
2. **SYN-ACK (Synchronize-Acknowledge):** Server say,s "Yes, let's talk!"
3. **ACK (Acknowledge):** Client says, "Great, here we go!"

Real-Life Analogy:

1. You: "Hey, got a minute?" 🙋
2. Friend: "Sure, what's up?" 🙋
3. You: "I wanted to ask about..." 💬

Port States - When we scan a port using nmap, it can be in one of these states:

```
sudo nmap -p 8000, 8001, 8002, 8003 -sS 192.168.122.145
```

State	Meaning	What Server Sends
OPEN - 8000	Service is running and accepting connections	SYN-ACK
CLOSED - 8001	Nothing running on this port	RST (Reset)
FILTERED - 8002-3...n	Firewall is blocking (no response)	Nothing

```
Client                                     Server
|                                         |
|                                         |
|-----1. SYN (Hi!)----->|
|                                         |
|<----2. SYN-ACK (Hi back!)-----|
|                                         |
|-----3. ACK (Let's talk!)----->|
|                                         |
|===== Connection Open =====|
```

```
1461 > http [SYN] seq=0
http > 1461 [SYN, ACK]
1461 > http [ACK] seq=1
```

After this, you are ready to send data

UNDERSTANDING PORTS AND SERVICES



What is a Port?

A **port** is a virtual "door" that allows different services to run on the same computer.

How It Works:

Your computer's IP address is like a **building address**: 192.168.1.100

Ports are like **apartment numbers**: :80, :443, :22

Full address: 192.168.1.100:80 = "Building 192.168.1.100, Apartment 80"

Port Number Ranges

Range	Category	Who Uses	Examples
0-1023	Well-Known Ports	System services	80 (HTTP), 443 (HTTPS), 22 (SSH)
1024-49151	Registered Ports	Applications	3306 (MySQL), 8080 (Alternative HTTP)
49152-65535	Dynamic/Private	Temporary	Random high ports

Total Ports: 65,535 per protocol (TCP and UDP)

Common Ports and Services

Port	Service	What It Does
20/21	FTP	File Transfer Protocol
22	SSH	Secure remote login
23	Telnet	Insecure remote login
25	SMTP	Sending email
53	DNS	Domain name lookups
80	HTTP	Websites (unencrypted)
110	POP3	Receiving email
143	IMAP	Email access
443	HTTPS	Websites (encrypted)
445	SMB	Windows file sharing
3306	MySQL	Database
3389	RDP	Windows remote desktop
8080	HTTP-Alt	Alternative web server

💡 Tip: Memorize the top 10 ports - they appear on exams and in real security work!

TYPES OF PORT SCANNING



1. TCP Connect Scan (Full Connection)

How it works: Completes the full three-way handshake.

Client → SYN → Server

Client ← SYN-ACK ← Server

Client → ACK → Server

Client → RST → Server (closes connection)

Characteristics:

- ☒ Most reliable
- ☒ Works without special permissions
- ☒ Easily detected (logs show full connection)
- ☒ Slowest method

Nmap command: `nmap -sT target`

Real-Life Analogy: Like knocking on every door, waiting for an answer, then leaving.

```
38194 > netbios-ssn [SYN] Seq=0
netbios-ssn > 38194 [SYN, ACK]
38194 > netbios-ssn [RST] Seq=1
```

The server is ready, but the client decided not to complete the handshake

TYPES OF PORT SCANNING



2. SYN Scan (Stealth/Half-Open Scan)

How it works: Only sends SYN, never completes handshake

Scanner → SYN → Target

Scanner ← SYN-ACK ← Target (port is OPEN!)

Scanner → RST → Target (abort! abort!)

Characteristics:

- ☒ Fast
- ☒ Stealthier (some systems don't log incomplete connections)
- ☒ Most popular scan type
- ☒ Requires root/admin privileges
- ☒ Still detected by modern IDS

Nmap command: `sudo nmap -sS target`

Real-Life Analogy: Knocking on the door, hearing "Who's there?", then running away before they open the door!

TYPES OF PORT SCANNING



3. FIN Scan

How it works: Sends FIN (finish) packet.

Scanner → FIN → Target

Response interpretation:

- No response = Port is OPEN (server confused, ignores weird packet)
- RST response = Port is CLOSED

Characteristics:

- ☒ Very stealthy
- ☒ Can bypass some firewalls
- ☒ Doesn't work on Windows (responds differently)
- ☒ Unreliable

Nmap command: `sudo nmap -sF target`

Real-Life Analogy: Saying "goodbye" to someone you never said "hello" to!

TYPES OF PORT SCANNING



4. NULL Scan

How it works: Sends a packet with NO flags set

Scanner → (empty packet) → Target

Response interpretation:

- No response = Port is OPEN or FILTERED
- RST response = Port is CLOSED

Characteristics:

- ☒ Very stealthy
- ☒ Can evade some IDS
- ☒ Doesn't work on Windows
- ☒ Less accurate

Nmap command: `sudo nmap -sN target`

TYPES OF PORT SCANNING



5. XMAS Scan

How it works: Sends packet with FIN, PSH, and URG flags set (like a Christmas tree lit up! 🎄)

Scanner → FIN+PSH+URG → Target

Response interpretation:

- No response = Port is OPEN or FILTERED
- RST response = Port is CLOSED

Characteristics:

- ☒ Stealthy
- ☒ Fun name!
- ☒ Doesn't work on Windows
- ☒ Easily detected by modern systems

Nmap command: `sudo nmap -sX target`

TYPES OF PORT SCANNING



6. UDP Scan

How it works: Sends UDP packets to ports

Scanner → UDP packet → Target

Response interpretation:

- No response = Port is OPEN or FILTERED (can't tell!)
- ICMP Port Unreachable = Port is CLOSED

Characteristics:

- ☒ The only way to find UDP services
- ✗ VERY slow (UDP is stateless)
- ✗ Often rate-limited by target
- ✗ Results are uncertain

Nmap command: `sudo nmap -sU target`

Note: UDP scans can take HOURS for 65,535 ports!

TYPES OF PORT SCANNING

Scan Type Comparison Table



Scan Type	Stealth Level	Speed	Accuracy	Requires Root	Windows Compatible
TCP Connect	Low	Slow	High	No	Yes
SYN Scan	Medium	Fast	High	Yes	Yes
FIN Scan	High	Fast	Medium	Yes	No
NULL Scan	High	Fast	Medium	Yes	No
XMAS Scan	High	Fast	Medium	Yes	No
UDP Scan	Low	Very Slow	Low	Yes	Yes

PORT SCANNING TOOLS



Nmap (Network Mapper)

- Nmap
- Zenmap (Nmap with GUI)
- Masscan (Fast)
- Unicornscan
- Rustscan
- hping3

In the absence of tools, sometimes roll your own?

- Python
- PowerShell

PORT SCANNING TOOLS

Nmap (Network Mapper)



The King of Port Scanners! 🏰

What it is:

- Most popular and powerful port scanner
- Free and open-source
- Works on Windows, Linux, macOS
- Pre-installed on Kali Linux

Key Features:

- Multiple scan types
- Service version detection
- Operating system detection
- Scripting engine (NSE)
- Output in multiple formats

Basic Syntax:

bash

```
nmap [Scan Type] [Options] [Target]
```

PORT SCANNING TOOLS

Zenmap (Nmap with GUI)



The Click-and-Scan Nmap!

What it is:

- Official GUI frontend for Nmap
- Cross-platform (Windows, Linux, macOS)
- Great for beginners who don't like pure CLI
- Let's you save and reuse scan profiles

Key Features:

- Predefined scan profiles (Intense scan, Quick scan, etc.)
- Visual network topology maps
- Scan results organized by host, port, service, OS guess, etc.
- Built-in Nmap command preview (shows the exact CLI command it's running)
- Can compare scan results over time

Basic Usage (Workflow):

1. Open Zenmap.
2. Type your Target (e.g., 192.168.1.10 or example.com).
3. Choose a Profile (e.g., "Intense scan", "Quick scan").
4. Click Scan.
5. Review results in tabs: Ports/Hosts, Topology, Host Details, Scans.

PORT SCANNING TOOLS



Masscan

The Speed Demon! 🏎️

What it is:

- Fastest port scanner in the world
- Can scan the entire internet in 6 minutes (theoretically!)
- Designed for speed over stealth

Characteristics:

- ☒ Incredibly fast (millions of packets per second)
- ☒ Similar syntax to Nmap
- ☒ Fewer features than Nmap
- ☒ Can overwhelm networks

Example:

bash

```
masscan -p80,443 192.168.1.0/24 -rate=1000
```

PORT SCANNING TOOLS

Unicornsscan

The Network Specialist! 🦄

What it is:

- Advanced information gathering tool
- Correlates stimulus and response

Characteristics:

- ☒ Very fast
- ☒ Detailed response analysis
- ☒ Steeper learning curve
- ☒ Less popular than Nmap



PORT SCANNING TOOLS



Rustscan

The Smart & Snappy Scanner ⚡

What it is:

- Modern port scanner written in Rust
- Designed for speed + smart scanning
- Often used alongside Nmap (Rustscan finds open ports, Nmap does deep analysis)

Key Characteristics:

- Very fast port discovery (async I/O, parallelism)
- Automatically opens ports to Nmap for service detection
- Simple, Nmap-like command-line experience
- Not as feature-rich as Nmap alone (scripts, OS detection, etc., still Nmap's job)

Example (fast scan + handoff to Nmap): `rustscan -a 192.168.1.10 -r 1-1000 -- -sV`

- `-a 192.168.1.10` → target host
- `-r 1-1000` → port range to scan
- `--` → everything after this is passed to Nmap
- `-sV` → Nmap's service version detection on the discovered open ports

PORT SCANNING TOOLS



hping3

The Packet Ninja Tool 🥷

What it is:

- Command-line TCP/IP packet crafter
- Like ping on steroids (TCP/UDP/RAW-IP, not just ICMP)
- Used for firewall testing, advanced port scanning, and network research

Key Uses / Features:

- Custom TCP/UDP/ICMP packets (set flags, ports, TTL, etc.)
- SYN scans to test if ports are open/filtered
- Traceroute-like functionality using TCP instead of ICMP
- Firewall/IDS evasion and testing (timing, fragmentation, flags)
- Bandwidth and packet-loss tests

Example: simple TCP SYN port probe: `sudo hping3 -S -p 80 -c 3 192.168.1.10`

- -S → set SYN flag
- -p 80 → destination port 80
- -c 3 → send 3 packets
- Reply flags indicate whether the port is open (SA), closed (RA), or filtered/no response.

Example: "stealthy" style scan over a small port range: `sudo hping3 -S 192.168.1.10 -p 20-25 --scan`

PORT SCANNING TOOLS



Rolling Your Own Port Scanner (When tools like Nmap/Masscan aren't available) 🔧

Python - Tiny TCP Port Scanner 📄

Idea: Try to connect to a set of ports; if the connection succeeds, → the port is open.

```
import socket
```

```
target = "192.168.1.10" # change to your target
```

```
ports = [22, 80, 443, 3389] # small demo list
```

```
print(f"Scanning {target}...")
```

```
for port in ports:
```

```
    s = socket.socket(socket.AF_INET, socket.SOCK_STREAM)
```

```
    s.settimeout(0.5) # half-second timeout
```

```
    try:
```

```
        result = s.connect_ex((target, port))
```

```
        if result == 0:
```

```
            print(f"[+] Port {port} open")
```

```
    except Exception as e:
```

```
        pass
```

```
    finally:
```

```
        s.close()
```

PORT SCANNING TOOLS



Rolling Your Own Port Scanner (When tools like Nmap/Masscan aren't available)

PowerShell – Quick Port Check

Using .NET's TcpClient in a loop:

```
$Target = "192.168.1.10"    # change to your target
$Ports  = 22,80,443,3389    # demo ports

Write-Host "Scanning $Target ..."
foreach ($Port in $Ports) {
    $tcp = New-Object System.Net.Sockets.TcpClient
    try {
        $iar = $tcp.BeginConnect($Target, $Port, $null, $null)
        $success = $iar.AsyncWaitHandle.WaitOne(500) # 500 ms timeout
        if ($success -and $tcp.Connected) {
            Write-Host "[+] Port $Port open"
        }
    } catch {
        # ignore errors for closed/filtered ports
    } finally {
        $tcp.Close()
    }
}
```

PORT SCANNING TOOLS



Tool Comparison

Tool	Speed	Features	Stealth	Best For
Nmap	Medium	Extensive	Good	"General purpose, detailed scans"
Masscan	Very Fast	Basic	Poor	"Large networks, quick sweeps"
Unicornscan	Fast	Advanced	Medium	"Network analysis, research"
Zenmap (Nmap GUI)	Medium	Extensive + GUI	Good	"Visual Nmap usage, beginners, reporting & topology views"
Rustscan	Very Fast	Intermediate	Medium	"Fast port discovery, then handing off to Nmap for details"
hping3	Fast	Advanced	Medium	"Firewall testing, custom packets, research-style scans"
Python (DIY script)	Slow	Basic	Good	"Learning, demos, small ad-hoc scans on known hosts"
PowerShell (DIY script)	Slow–Medium	Basic	Good	"Quick checks from Windows hosts, admin scripting workflows"

Recommendation: Start with Nmap, use Masscan for large scans.

PING SWEEP TECHNIQUES



What is a Ping Sweep?

Ping sweep = Checking which IP addresses are "alive" (responding) on a network. Think of it like calling every phone number in a list to see which ones answer!

Why Ping First?

Problem: Scanning all 65,535 ports on 254 hosts = **16,711,170 checks!** 🕒

Solution: Ping sweep to find live hosts first, then scan only those.

Time saved: Can reduce scan time from hours to minutes!

ICMP Echo (Ping)

How it works:

You → ICMP Echo Request → Target

You ← ICMP Echo Reply ← Target (Host is UP!)

Nmap command:

bash

```
nmap -sn 192.168.1.0/24
```

Translation: "Scan network 192.168.1.0-255, but only check if hosts are up (-sn = no port scan)"

PING SWEEP TECHNIQUES

Network Ranges Explained



CIDR Notation:

Notation	Range	Number of IPs	Use Case
192.168.1.1	Single IP	1	Scan one computer
192.168.1.0/24	192.168.1.0-255	256	Typical home/office network
192.168.0.0/16	192.168.0.0-255.255	65,536	Large organization
10.0.0.0/8	10.0.0.0-255.255.255	16,777,216	Entire private network class

Wildcard Notation:

bash

- 192.168.1.* # Same as 192.168.1.0/24
- 192.168.1.1-50 # Only IPs 1 through 50
- 192.168.1.1,2,3,4 # Specific IPs

PING SWEEP TECHNIQUES



Alternative Discovery Methods

1. ARP Scan (Local Network Only)

bash

```
nmap -PR 192.168.1.0/24
```

Best for: Same network segment (fastest!)

2. TCP SYN Ping

bash

```
nmap -PS80,443 192.168.1.0/24
```

Best for: When ICMP is blocked

3. UDP Ping

bash

```
nmap -PU 192.168.1.0/24
```

Best for: Finding hosts that block TCP

FIREWALL AND IDS EVASION TECHNIQUES



What are Firewalls and IDS?

Firewall 🧱

- Blocks unwanted network traffic
- Like a security guard at a building entrance
- Rules: "Allow web traffic, block everything else"

IDS (Intrusion Detection System) 🔔

- Monitors the network for suspicious activity
- Like a security camera system
- Alerts: "Someone is port scanning!"

Why Evade Detection?

As Ethical Hackers:

- Test if security controls can be bypassed
- Validate security investments
- Improve defenses

Real Attackers:

- Avoid getting caught
- Complete reconnaissance undetected

FIREWALL AND IDS EVASION TECHNIQUES



Evasion Technique 1: Slow Scans

Problem: Fast scans trigger alerts (1000s of packets per second)

Solution: Scan slowly!

bash

T0 = Paranoid (insanely slow, 5 minutes per port!)

nmap -T0 target

T1 = Sneaky (very slow)

nmap -T1 target

T2 = Polite (slow)

nmap -T2 target

T3 = Normal (default)

nmap -T3 target

T4 = Aggressive (fast)

nmap -T4 target

T5 = Insane (very fast, may miss results)

nmap -T5 target

Evasion Technique 2: Fragmentation

What it does: Breaks packets into tiny pieces

Why it works: Some firewalls/IDS can't reassemble fragments properly

bash

nmap -f target # Fragment packets

nmap -ff target # Fragment even more (8 bytes)

nmap -mtu 16 target # Set custom fragment size

Evasion Technique 3: Decoys

What it does: Makes the scan appear to come from multiple sources

Why it works: Hard to tell which IP is the real attacker

bash

Use random decoys

nmap -D RND:10 target

Use specific decoys

nmap -D decoy1,decoy2,ME,decoy3 target

Result: Firewall logs show scans from 10 different IPs!

FIREWALL AND IDS EVASION TECHNIQUES



Evasion Technique 4: Source Port Manipulation

What it does: Scan from a trusted port (like 53 for DNS)

Why it works: Some firewalls allow traffic from certain ports

bash

```
nmap --source-port 53 target
```

```
nmap -g 53 target    # Same thing
```

Evasion Technique 5: Randomize

Targets

What it does: Scan IPs in random order

Why it works: Doesn't trigger "sequential scan" alerts

bash

```
nmap --randomize-hosts 192.168.1.0/24
```

Evasion Technique 6: Spoof MAC Address

What it does: Change your MAC address

Why it works: Bypass MAC filtering

bash

```
nmap --spoof-mac 0 target    # Random MAC
```

```
nmap --spoof-mac Apple target # Apple device MAC
```

```
nmap --spoof-mac 00:11:22:33:44:55 target # Specific MAC
```

Combining Evasion Techniques

Maximum stealth scan:

bash

```
sudo nmap -sS -T1 -f --randomize-hosts -D RND:10 --source-port 53  
192.168.1.100
```

Translation: SYN scan, very slow, fragmented, random host order, 10 decoys, from port 53

Tradeoff: Will take MUCH longer to complete!

LEGAL AND ETHICAL CONSIDERATIONS



The Law

Malaysia:

- Computer Crimes Act 1997 - Up to 10 years imprisonment
- Unauthorized access includes reconnaissance

USA:

- Computer Fraud and Abuse Act - Federal crime
- Can result in 5-20 years in prison

UK:

- Computer Misuse Act 1990 - Up to 10 years

When Port Scanning is Legal

☑ Allowed:

1. Your own systems - Scan what you own
2. With written permission - Signed authorization from the owner
3. Published test systems - scanme.nmap.org, testphp.vulnweb.com
4. Educational labs - Controlled environment with proper authorization

✗ NOT Allowed:

1. Your school/university network - Even though you use it!
2. Your employer's network - Unless specifically authorized
3. Any website - Even if it's "just to check"
4. Your neighbor's WiFi - Even if it's open!

Best Practices for Ethical Hackers

The Rules:

1. Always get written authorization

- Email is NOT enough!
- Need a formal engagement letter/contract

2. Define the scope clearly

- Which IPs/domains are allowed?
- What times can you scan?
- What techniques are permitted?

3. Document everything

- Commands run
- Results obtained
- Date and time stamps

4. Report responsibly

- Don't share vulnerabilities publicly
- Give the organization time to fix
- Follow disclosure policies

5. Respect rate limits

- Don't crash systems with aggressive scans
- Use appropriate timing templates

Safe Practice Targets (Officially Authorized for Testing)

Target	Purpose	Notes
scanme.nmap.org	Nmap test server	Maintained by Nmap project
testphp.vulnweb.com	Web app testing	Acunetix test site
demo.testfire.net	Banking app test	IBM AppScan demo
Your own VMs	Complete control	Best option!

⚠ **Port Scanning Without Permission is ILLEGAL!**



Summary: Key Takeaways



TCP/IP Essentials:

- ☒ Three-way handshake: SYN → SYN-ACK → ACK
- ☒ Port states: OPEN, CLOSED, FILTERED
- ☒ TCP = reliable, UDP = fast but unreliable

Scan Types:

- ☒ TCP Connect = Most reliable, easily detected
- ☒ SYN Scan = Best balance (fast, fairly stealthy)
- ☒ FIN/NULL/XMAS = Very stealthy, unreliable

Tools:

- ☒ Nmap = Swiss Army knife (use this 95% of the time)
- ☒ Masscan = Speed demon (large networks)

Evasion:

- ☒ Timing templates (-T0 to -T5)
- ☒ Fragmentation (-f)
- ☒ Decoys (-D)

Ethics:

- ☒ ALWAYS get permission
- ☒ Only scan authorized targets
- ☒ Port scanning without permission = CRIME

Thank You

ANY QUESTIONS?

